

AISECURITYPULSE: Automating Security Issue Reports for AI Models

Tuong Phuc Ngo^{1*}, Sajjad Nakhwa^{2*}, Weijun Li¹, Anudeex Shetty^{1,3}, and Qionгкаi Xu^{1,3}

¹ Macquarie University, Sydney, Australia

² Indian Institute of Technology Bombay, Mumbai, India

³ The University of Melbourne, Melbourne, Australia

Abstract. Recent advances in Large Language Models (LLMs) have driven widespread adoption across consumer and enterprise applications, but also exposed critical security vulnerabilities including privacy leaks, jailbreaks, and adversarial misuse. These issues remain underreported due to the fast-paced nature of AI research and the absence of a standardised reporting framework. We introduce AISECURITYPULSE⁴, a centralised platform that automates and streamlines the responsible disclosure of security issues in AI models. The platform supports anonymous yet cryptographically verifiable submissions, enabling impartial peer review while protecting reporters, and integrates an automated notification pipeline that promptly informs the relevant model providers.⁵

Keywords: AI Security · LLMs · Vulnerability Disclosure

1 Introduction

The rapid integration of Large Language Models (LLMs) across domains has intensified calls for transparent and accountable vulnerability auditing [2,3]. The Coordinated Flaw Disclosure (CFD) framework [2] established foundational principles for responsible AI disclosure; building on this, NeurIPS [4] and ACL [1] adopted complementary policies (including a 30-day embargo) to balance transparency with provider response time.

In practice, disclosure still relies on ad-hoc channels such as direct emails to model providers (*e.g.*, OpenAI [5]) or third-party platforms like HackerOne⁶. Existing tools such as FuzzyAI⁷ focus on isolated benchmarking or bug tracking, failing to connect researchers, developers, and model providers in a single workflow. These approaches collectively produce fragmented records, limited transparency, and inefficient stakeholder coordination.

* Equal contribution.

⁴ Our platform can be found at: <https://security-pulse-drab.vercel.app/>.

⁵ AISECURITYPULSE demo video is available at https://drive.google.com/drive/folders/1tbSGFSnAKb-PoiFOcr-kpm4n_6jRdfS7?usp=sharing.

⁶ HackerOne: <https://www.hackerone.com/>.

⁷ FuzzyAI: <https://github.com/cyberark/FuzzyAI>.

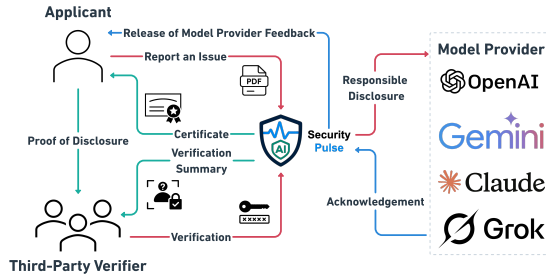


Fig. 1: Interactions between stakeholders through AISECURITYPULSE, with disclosure and verification components in the workflow.

Data Leakage from Partial Transformer Gradients

A new security report for the model: BERT

Summary of Findings

Language models are vulnerable to data reconstruction attacks using just 0.54% of gradient information.

Report Details

Report Type: Security Vulnerability
 Submission: Public
 Reporter Email: weijunli.wj@gmail.com
 Attachment: 2024.emnlp-main.275.pdf
 Timestamp: 11/15/2025, 12:25:23 PM UTC

Fig. 2: Automated notification sent to model providers.

We introduce AISECURITYPULSE to address this gap. The platform lets stakeholders submit structured reports covering jailbreaks, prompt injections, and ethical compromises; associate them with specific providers and models; optionally submit anonymously with cryptographic proof of authorship; and trigger automated provider notification, all within a single, open-source interface.

2 System Description

2.1 Architecture Overview

AISECURITYPULSE is built on two core modules: (1) an *automated responsible disclosure pipeline* that routes structured reports to the appropriate model providers, and (2) an *anonymous verification system* that lets researchers prove authorship without revealing their identity. Figure 1 illustrates the end-to-end stakeholder workflow. Applicants submit structured reports, optionally with anonymity and evidence attachments, which are then verified by third-party verifiers and forwarded to the relevant model provider via responsible disclosure; the provider issues an acknowledgement and feedback, and the applicant receives a certificate as proof of disclosure.

2.2 Organisation Mapping and Model Coverage

Each AI provider is associated with a designated security contact stored in the platform database. On submission, AISECURITYPULSE retrieves the appropriate address and dispatches the report automatically; reporters can also add missing organisations and models directly through the interface. To maintain a comprehensive and up-to-date model registry, the platform synchronises with the OpenRouter API⁸ via a cron job, currently covering 139 models from 67 providers.

⁸ OpenRouter: <https://openrouter.ai/>.

2.3 Automated Notification Pipeline

Upon report submission, AISECURITYPULSE triggers a Supabase Edge Function integrated with the Resend⁹ email API to notify the corresponding organisation. The system performs a real-time database lookup to resolve the organisation’s current security contact; if the reporter supplies new provider metadata, the platform uses that directly, bypassing cached lookups. Notifications follow a standardised HTML template (responsive for web and mobile) containing report metadata, a quoted findings summary, the affected model name, submission timestamp (UTC), and a PDF attachment. Anonymous reports include an explicit privacy notice to the recipient. Figure 2 shows a representative notification as received by a model provider.

2.4 Certified Keys for Anonymous Review

Responsible disclosure must balance reporter anonymity with verifiable proof of contribution, especially as venues such as ACL [1] now require documented prior disclosure. When a user submits anonymously, the browser generates a public-private RSA key pair locally via the Web Crypto API (RSASSA-PKCS1-v1_5, 2048-bit modulus, SHA-256). A hash of the report (binding organisation, model, report type, and report ID) is signed with the private key; the Base64-encoded public key and signature are stored alongside the report in Supabase. On successful submission, the platform downloads a JSON certificate containing the `report_id`, `public_key`, `signature`, and `private_key` to the reporter’s machine, serving as portable proof of authorship. A dedicated verification page accepts the report metadata and, for anonymous reports, the public key and signature, returning a blurred report preview upon successful validation. This design aligns with CFD principles [2] and NeurIPS guidance [4], ensuring identity protection while preserving traceability.

2.5 Provider Outreach

We contacted major AI providers to catalogue their existing disclosure channels. OpenAI and Inflection AI confirmed dedicated security emails; Perplexity and xAI prefer structured web forms or HackerOne; Cohere, Google, and Nvidia acknowledged our inquiry and are pending response; Meta, Mistral, Anthropic, and Alibaba Cloud have not yet responded. This heterogeneity in disclosure practices underscores the need for a centralised intermediary such as AISECURITYPULSE.

3 Experiments

3.1 Non-forgability and Integrity

To validate tamper-resistance, we attempted to verify a legitimately signed report after introducing some modifications to `report_id` and `model_metadata`

⁹ Resend: <https://resend.com>

separately; both returned `False`, confirming that any payload alteration invalidates the certificate and prevents retroactive modification of vulnerability reports. To further stress-test the scheme, we generated 1,000 random `report_id` values and submitted them to the verification pipeline, none of which produced a valid result. The security of user reports is maintained due to the extremely low collision probability of the underlying hash function, ensuring that an adversary cannot fabricate a valid certificate without access to the original private key.

3.2 Load Testing

We evaluated platform robustness under heavy traffic using Grafana k6,¹⁰ simulating 100 concurrent virtual users performing resource-intensive operations over 12 minutes. This generated a sustained load of 51.3 requests/s ($\approx 184\text{k}$ requests/hr). The platform achieved **99.99% reliability** (4 failures in $\sim 37,000$ requests) and **99.71% performance stability**, with a 95th-percentile request latency of 260.51 ms and only 0.29% of requests exceeding the 1-second threshold. These results confirm that AISECURITYPULSE can sustain concurrent, heavy traffic without compromising reliability or user experience.

4 Conclusion

We presented AISECURITYPULSE, a centralised platform that streamlines responsible security disclosure for LLMs and AI systems. By combining anonymous yet cryptographically verifiable submissions, an automated provider notification pipeline, and an open-source architecture, AISECURITYPULSE addresses the fragmented state of AI vulnerability reporting. In the long term, the accumulated dataset of reports will support trend analysis, provider response-time benchmarking, and the development of defensive strategies across the research community.

References

1. ACL Conference Committee: ACL policy on publication ethics. <https://aclweb.org/adminwiki> (2025), section on co-ordinated disclosure
2. Cattell, S., Ghosh, A., Kaffee, L.A.: Coordinated flaw disclosure for ai: Beyond security vulnerabilities. In: Proceedings of the AAAI/ACM Conference on AI, Ethics, and Society. vol. 7, pp. 267–280 (2024)
3. Longpre, S., Klyman, K., Appel, R.E., Kapoor, S., Bommasani, R., Sahar, M., McGregor, S., Ghosh, A., Blili-Hamelin, B., Butters, N., et al.: Position: In-house evaluation is not enough. towards robust third-party evaluation and flaw disclosure for general-purpose ai. In: Forty-second International Conference on Machine Learning Position Paper Track (2025)
4. NeurIPS Conference Committee: NeurIPS code of ethics. <https://neurips.cc/public/EthicsGuidelines> (2024), section on Responsible release and publication strategy
5. OpenAI: Coordinated vulnerability disclosure policy. <https://openai.com/policies/coordinated-vulnerability-disclosure-policy/> (2025)

¹⁰ Grafana k6: <https://k6.io/>.